Authentication

Passwords

- Passwords are widely used to **authenticate** users
  - Authenticate = Check that you are who you say you are
- Websites should never need to actually have your password, they use **hashing** instead
- Hashing uses maths to turn the password into code in a way that can’t be reversed

Hashing is a one-way function

”I can read this”

Hash Function
(SHA-256)

7c914ae5b2604eab8c550
193ffbeb5ddc1582afeaee
9eefdb2f046f8652bb9d8

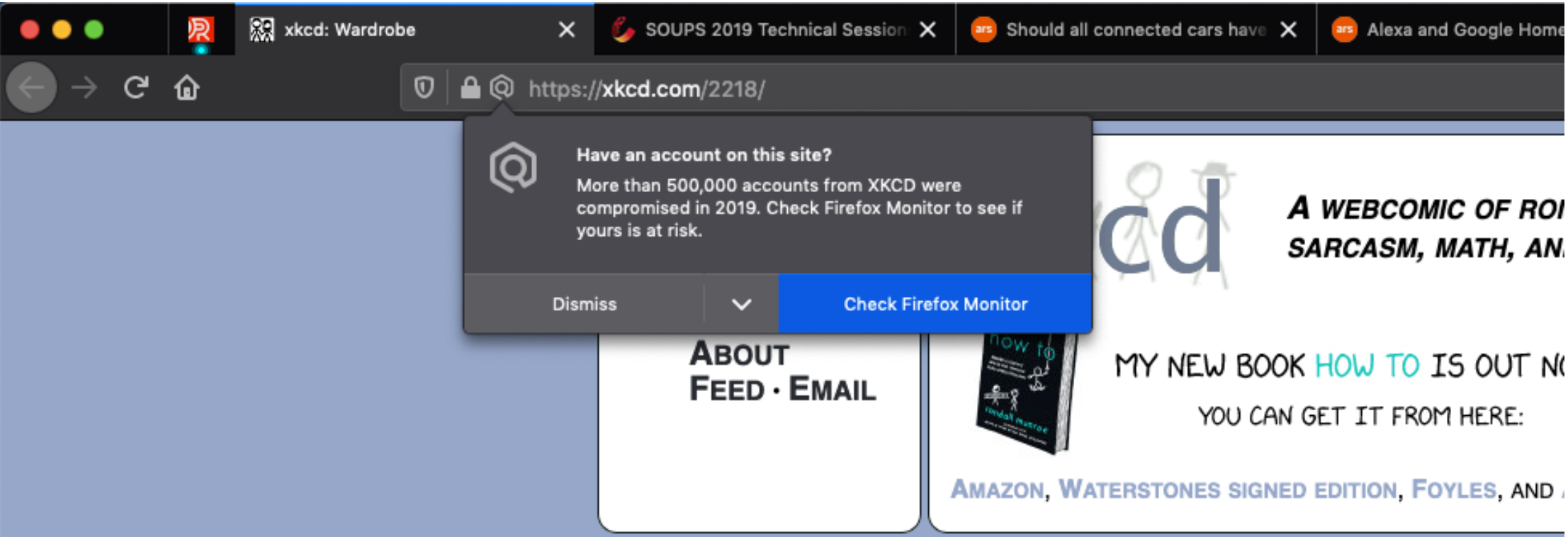
What happens to the juice?

- The same password will produce the same hash (juice) every time
- Legitimate websites just store the hash (juice)
- When you type in your password to log in, your computer juices it and <u>only sends the juice to be checked</u>
- If it matches what they have on file, you are who you say you are
- If stored passwords are exposed in a data breach, they are usually juice
- Many lists of juiced passwords are available for sale

Northumbria University NEWCASTLE

The importance of unique passwords

- https://haveibeenpwned.com/



How do hackers turn juice back into passwords?

- This is called **password cracking**
- Because the hackers have a list of hashes, they aren’t restricted to a few guesses (like they would be when using a website, or when trying to get into a phone)
- Their process:
  - Pick a password to try
  - Juice the password
  - Check the list. Has anyone used this password?
  - Repeat
- Sound slow? They can check thousands, millions, or even billions per second!

Password cracking option 1: brute force

- Simply try every possible password, starting with the shortest
- If you use a password that is short and simple, they **will** find it

brute-force-visualizer_v3.html

First hurdle: Get past brute force

- Passwords that are longer and use different types of characters (upper case, numbers, symbols) get exponentially harder to crack this way
- Therefore, passwords should be **strong**
- But, that’s not all!

Password cracking option 2: dictionary

- Having a strong password is no help if it is predictable
- Before trying all possible passwords, they'll try a list of likely possibilities, including:
  - Every word in the dictionary (doesn't matter how long)
  - Every password that has previously been exposed in a breach
  - Common patterns of these with added numbers/symbol replacements
- Therefore your password should be **unique**
- It should not be used anywhere else

Second hurdle: be unpredictable

Password strength checker

- https://bitwarden.com/password-strength/

Exposed passwords checker

- https://haveibeenpwned.com/Passwords

Tips for creating good long passwords

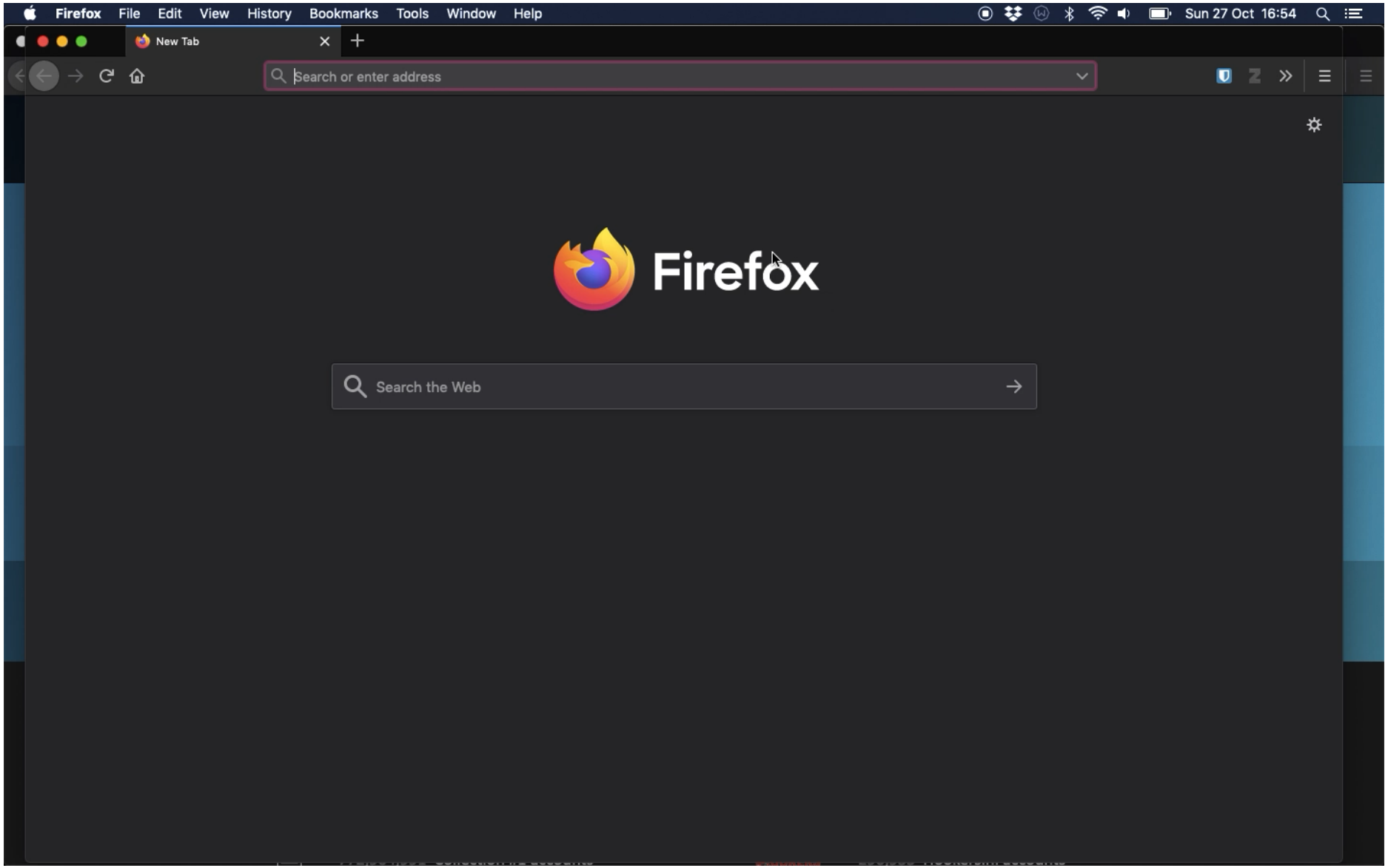
- Three or more random words
  - Truly random and unrelated to each other
  - Ideally: Include upper case, lower case, a number and a symbol
  - E.g. potato-9feline-Vacuum
- Passphrases
  - “I have a hard time remembering passwords for online account” => **Ihahtrp4ola**
  - “Northumbria University teaches me about security every week” => NUtmas3w
- Non-personal!
- People may still try to guess your password manually if they’re targeting you directly. Don’t use
  - Names of people close to you
  - Dates, addresses, phone numbers
  - Anything people might find out about you

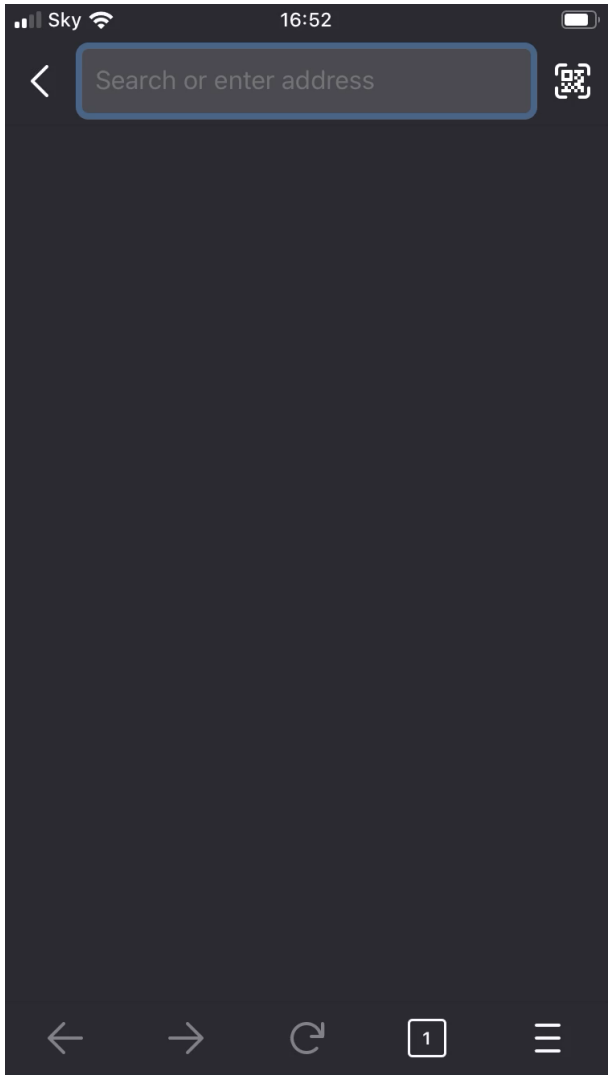
You might need to compromise

- Key accounts should be unique (bank, email, iCloud)
- You can have account tiers: low/medium/high importance
- You could use a “Password for Life”
  - A main strong password that you tailor to different accounts
- Unique passwords can be written down, but **securely**

Another approach: Password Managers

- Password managers are services that store your passwords for you.
- You need to remember one very strong **master password**
- Stored passwords are **encrypted** using the master password
  - Encryption is like hashing (juicing) but it can go both ways
- Without the master password, nobody can access the passwords, even if the service is breached
- Password managers can:
  - generate excellent passwords for you
  - warn you if your passwords are unsafe
  - automatically remember new passwords
  - type them in for you


Firefox File Edit View History Bookmarks Tools Window Help
Sun 27 Oct 16:54
New Tab
Search or enter address
Firefox
Search the Web


Sky
16:52
Search or enter address
1

Choosing a password manager

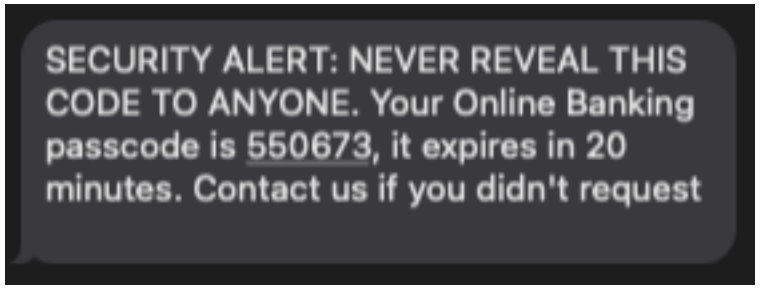
- Built in (Apple, Google, Samsung)
  + Convenient, free
  - Ties you into your ecosystem
- Browser based (e.g. Google Chrome, Firefox)
  + Convenient, free
  - May lack functionality, ties you into your browser
- Standalone (e.g. Bitwarden, Lastpass, many more)
  + Versatile, use across different systems
  - Can cost money, or have a restrictive free tier

Two Factor Authentication (2FA)

Using multiple factors

- Passwords prove who you are by providing something only you know. This is a **factor**.
- Other main types of factor
  - Something that you **have** (e.g. your mobile phone)
  - Something that you **are** (e.g. your fingerprint)
- Two-factor authentication (2FA) introduces a second factor in case someone learns your password.
- With 2FA, someone who is not near you in the real world usually won’t be able to access your account, **even with the password.**

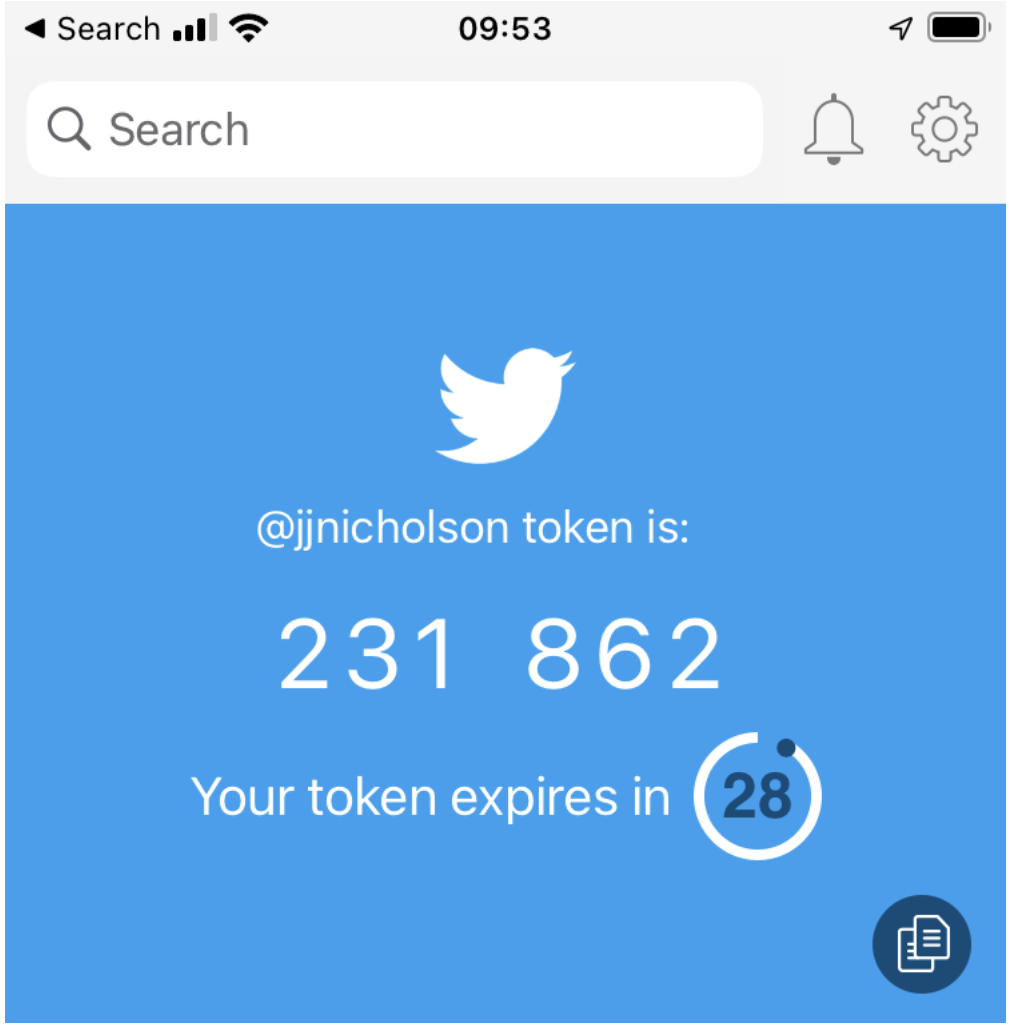
SMS Text Codes

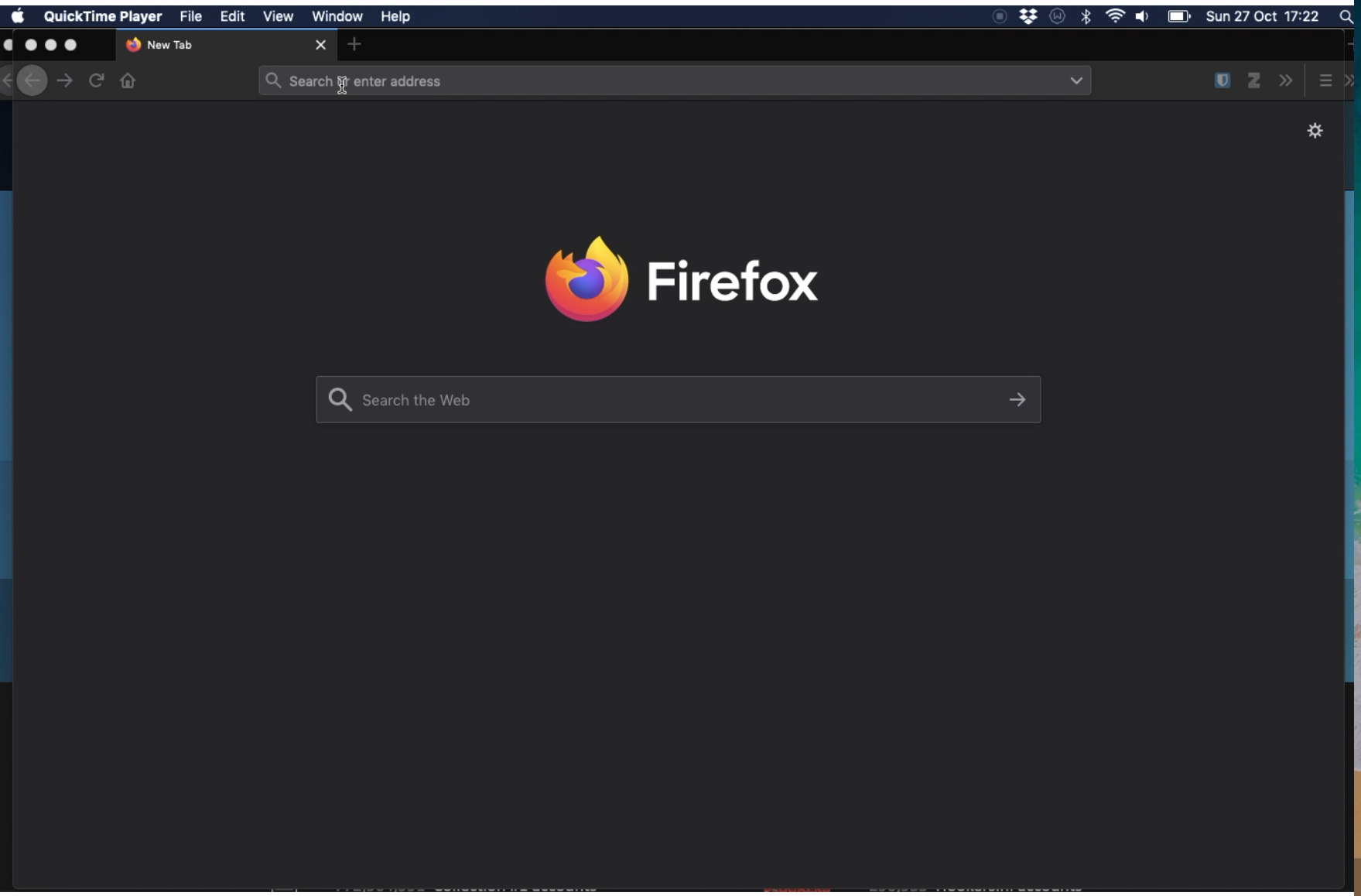


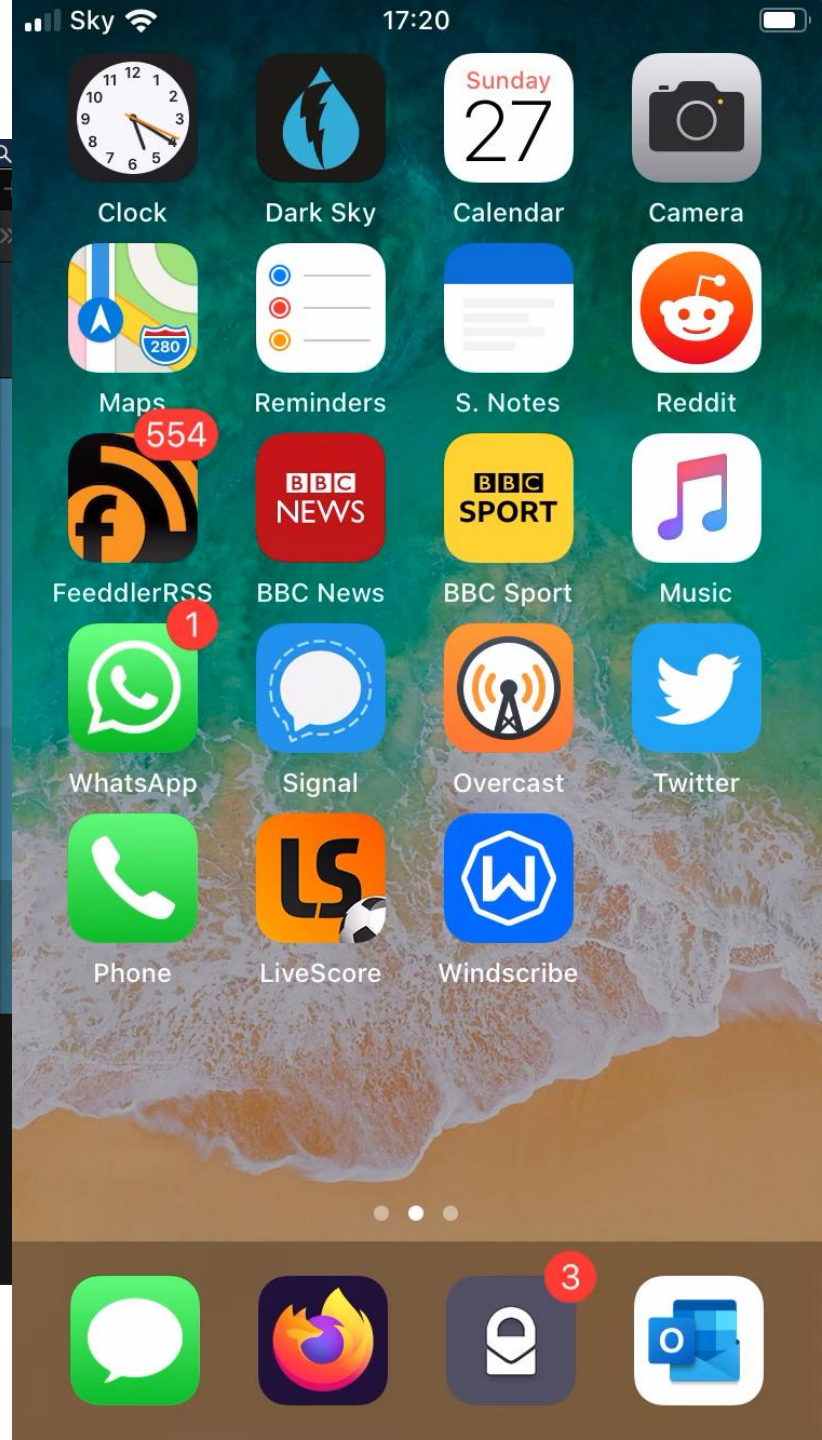
- It is common to use codes sent by text message. Typing the code proves that you **have** your mobile phone.
- Convenient, as only need to give out number and code will be sent out when required.
- Make sure that if you use this option you can rely on good mobile signal.
- Not foolproof – determined hackers can sometimes hijack sim cards so that they receive the message instead

Authenticator Apps

- Google Authenticator
- Microsoft Authenticator
- Duo Mobile
- Authy




QuickTime Player File Edit View Window Help
Sun 27 Oct 17:22
New Tab
Search or enter address
Firefox
Search the Web

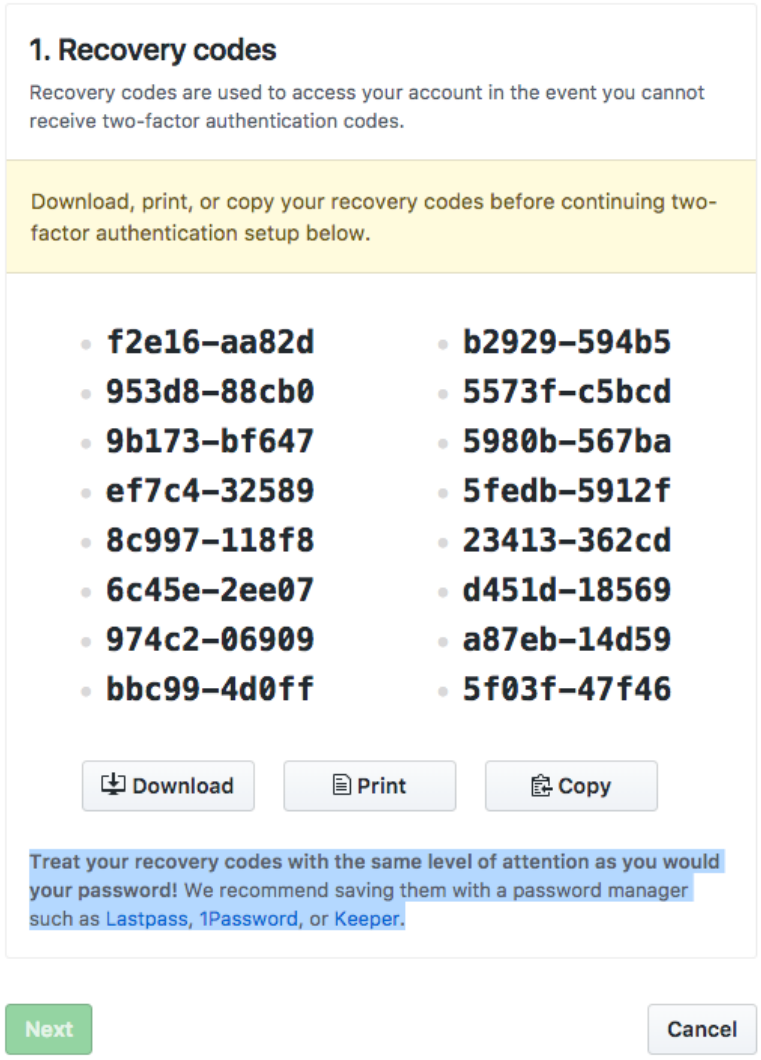

Sky
17:20
Clock
Dark Sky
Sunday
27
Calendar
Camera
Maps
Reminders
S. Notes
Reddit
554
FeeddlerRSS
BBC News
BBC Sport
Music
1
WhatsApp
Signal
Overcast
Twitter
Phone
LiveScore
Windscribe
3

Drawbacks

- Slower
  - But only need to enter code during first login on each device (or at least irregularly)
  - On unknown devices, yes, ask…
- Need extra device (usually a mobile phone)
- Can get locked out: e.g. if you change phone

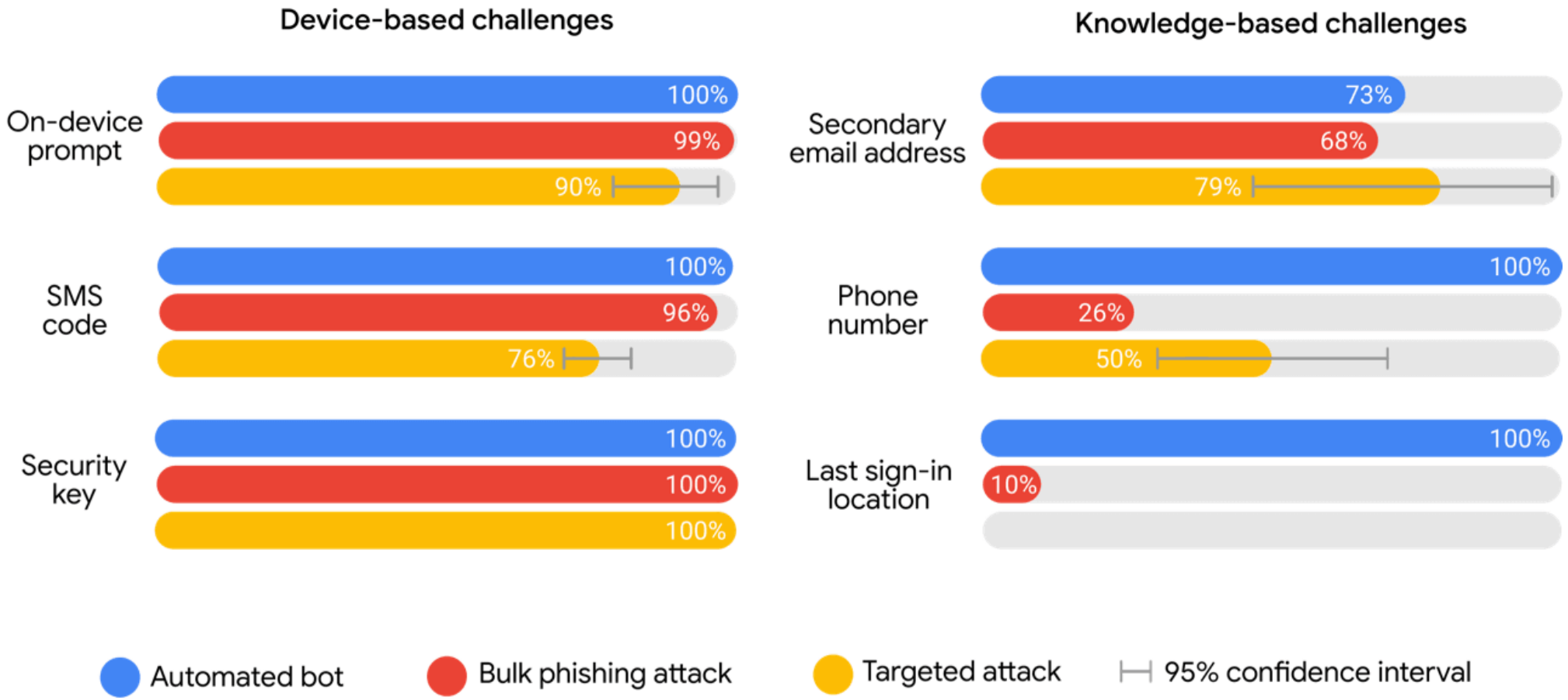
Back Up Codes

- These are important!
- They will bypass 2FA
  - If you lose your phone
  - If you change your phone
  - If you need someone to access your account
- Save carefully:
  - An attacker can use these to bypass 2FA



Why should I use it?

Account takeover prevention rates, by challenge type



Tips

- Enable for most important accounts (e.g. email, Amazon), but doesn’t hurt to do it for other accounts too

- What services support 2FA?: https://2fa.directory/gb/

- Save Back Up Codes
  - Obtained when enabling 2FA

Password Alternatives

One-Time Passwords / Magic Links

- Sometimes, instead of using passwords, websites will email or text a code or link to you when you want to log in
- The logic
  - Your email account should be well secured already
  - In most cases, the email is how you reset a password anyway
  - Only used once and will expire, so a compromised code is less risk than a compromised password
  - No need to remember anything
- But
  - Password AND Code (i.e. 2FA) is still much stronger
  - Remember to never share one-time codes with anyone

Password Alternatives
Single Sign-On (SSO)

- Sometimes, websites or services will offer you to “Sign in with …”
  - Google, Facebook, Apple etc
  - A place of work
- Benefits
  - Quick
  - No new passwords
  - As secure as your existing login (e.g. maybe you have 2FA set up)
- Downsides
  - That company gets data about where you sign in
  - If your login for that company is compromised, this new account is too
  - Makes you dependent on them
  - Phishing risk

Password Alternatives

Passkeys

- Up and coming, not yet widely used (but growing)
- Your device creates a pair of virtual keys
  - One on the service you'll use them to access
  - One on your device or password manager (passkey)
- These two keys allow the service to ask your device a question that could only be answered if it has the passkey
- The passkey is kept on your device or password manager
- Your device or password manager will only give the answer if you tell it to (e.g. using your fingerprint to check who you are)
- Passkeys are very secure, just not very common yet

Authentication summary

- Passwords should be **strong** so that they can't be cracked if they are leaked
  - Three (truly) random words is an easy way to make strong passwords
  - Don't be predictable
- Passwords should be **unique** so that one data breach or accidentally shared password does not affect other accounts
  - Ideally, every account has a different password
  - Password managers can make this easy
- Use **Two-Factor Authentication (2FA)** on important accounts
  - SMS is better than nothing, but authenticator apps are best
  - Save your backup codes if you use an app
- Be open to using passkeys when they become more common